Title of the project :-

Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity.

Overview :-

The project aims to develop an AI-driven identity verification system that enhances online security by analysing and verifying user identities based on their online behaviour patterns.

This system uses advanced machine learning techniques to create a robust user profile, distinguishing between legitimate users and suspicious activities. It addresses the pressing issue of unauthorised access, fraudulent transactions, and cyber threats across various online platforms and services. The primary objective is to enhance online security significantly by scrutinising and validating user identities through their online behaviour.

The system employs advanced machine learning techniques such as deep learning, neural networks, and natural language processing to establish comprehensive behavioural profiles for each user, which adapt and evolve with the user's behaviour over time. Real-time anomaly detection is a key feature of the system, identifying deviations from established user behaviour profiles and responding promptly to mitigate potential security threats.

Multi-factor verification is also implemented to bolster security, triggering additional verification steps when anomalies are detected. User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data. The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations. Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours.

User and administrator alerts ensure transparent communication and provide guidance on resolving potential security issues. Secure data storage and management components are included to protect sensitive user profiles and anomaly data. The system includes an integration layer for seamless interaction with various online platforms and services. Monitoring and reporting are integrated for performance and security, providing transparency and accountability. Scalability and load balancing are designed to handle growing user bases, while security and compliance are prioritised by encrypting data in transit and at rest, employing firewalls, intrusion detection systems, and adhering to data protection and privacy regulations. Cloud infrastructure is an optional option for flexibility and scalability. Continuous training and optimization of machine learning models ensure the system remains effective against evolving threats and user behaviours. Geographic distribution can enhance redundancy and performance by deploying components in multiple geographic

List of teammates–

S.no	name	collage	contact
1.	Chanchal.L	Rd national college of arts and science	9486766742
2.	Aneesha M	RD national college of arts and Science	9790179272
3.	Praveen kumar N	RD national college of arts and Science	9345779340
4.	Giriraj k	RD national college of arts and Science	9500956386
5.	Elambarthi	RD national college of arts and Science	7904637507

List of Vulnerability Table

S.no	Vulnerability Name	CWE/CVE - No
1	Improper Sanitization of File Paths	CWE- 284: Improper Access Control
2	2 Invalid Certificate	CWE-395: Improper Certificate Validation
3.	Missing X-Frame-Options Header	CWE-1021: Design Improper Restriction of Rendered UI Layers or Frames
4.	9 TLS Version 1.0 Protocol Detection	CWE-327: Use of a Broken or Risky Cr
5.	web.config File Information Disclosure to an Unauthorised Control Sphere	CWE-497: Exposure of Sensitive System Information

REPORT:-

Practice Website: http://www.itsecgames.com/

Vulnerability Name:- Improper Sanitization of File Paths

CWE/CVE : Improper Access Control

OWASP Category: A01:2021-Broken Access Control Description: The product does not restrict or incorrectly restricts access to a resource from an unauthorized actor.

Business Impact: This vulnerability is significant, as it can lead to unauthorized access to sensitive data or files, potentially causing data breaches, privacy violations, and loss of user trust. Affected sites may also require configuration changes after applying a security release. Steps to Reproduce: https://www.shodan.io/host/31.3.96.40

Recommendation: 1.Apply Security Updates: The primary recommendation is to apply the security update provided by Drupal as soon as it becomes available. Security updates typically include fixes for known vulnerabilities like this one.

2.Review Configuration: After applying the update, review your Drupal site's configuration to ensure that private files remain protected as intended. Make any necessary adjustments to your site's file permissions or access controls.

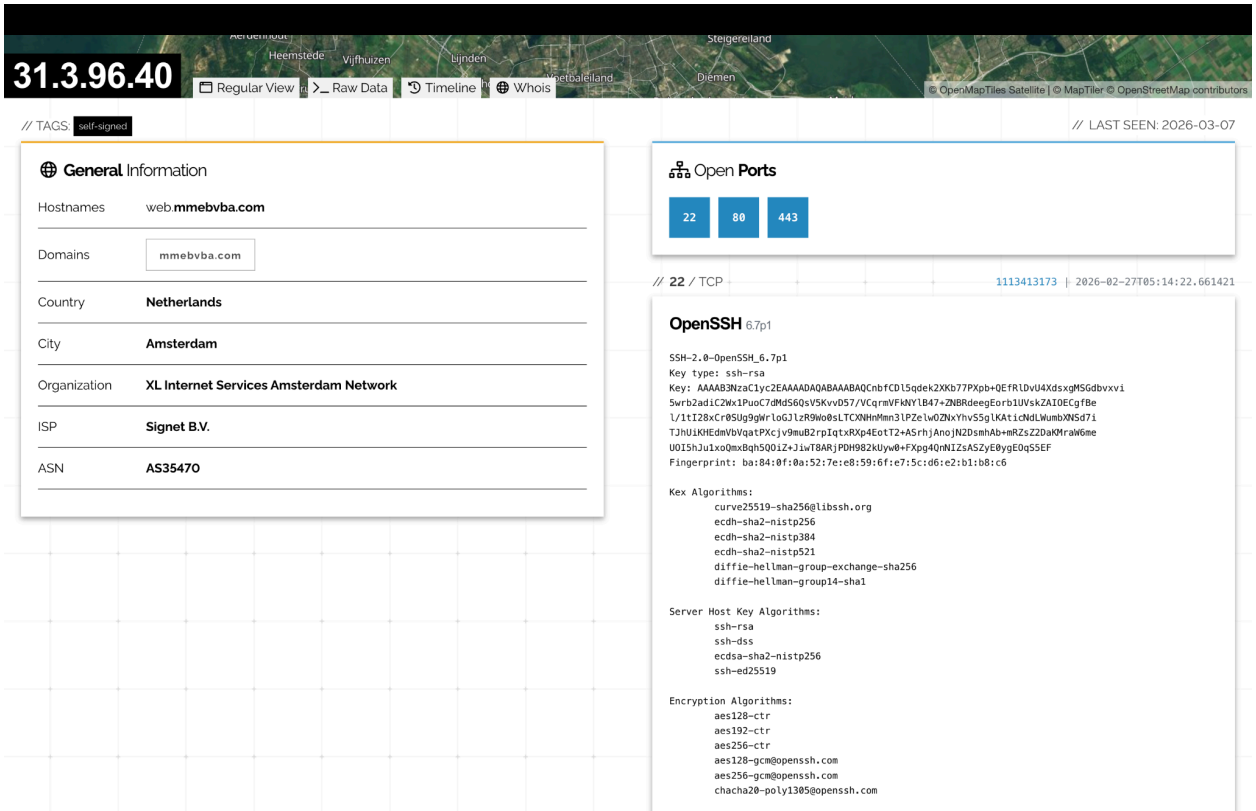
3.Regular Audits: Conduct regular security audits and vulnerability assessments to identify and address potential security issues in your Drupal site.

4.Access Control: Implement strong access controls to ensure that only authorized users can access private files. Review and restrict file access permissions as needed.

5.Data Minimization: Minimize the amount of sensitive data stored on your Drupal site. Only store data that is necessary for your site's functionality.

Steps to Reproduce:

https://www.shodan.io/host/31.3.96.40



OWASP Category:

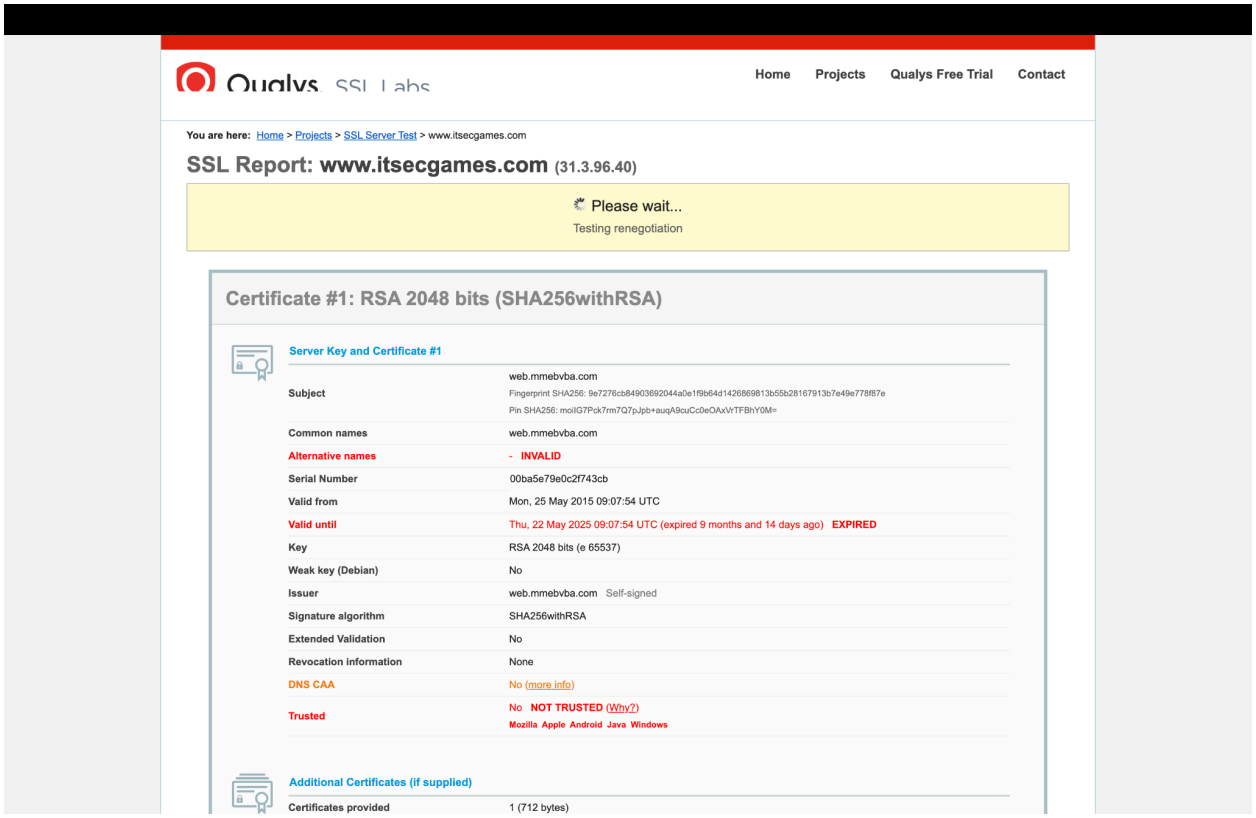
A07:2021 – Identification and Authentication Failures Description: When a certificate is invalid or malicious, it might allow an attacker to spoof a trusted entity by interfering in the communication path between the host and client. The product might connect to a malicious host while believing it is a trusted host, or the product might be deceived into accepting spoofed data that appears to originate from a trusted host.

Business Impact:

Improper certificate validation can lead to a range of security threats which includes Man-in-the-middle attacks(Attackers can intercept communication between two parties and read or modify the data exchanged between them),Data breaches:(Attackers can gain unauthorized access to sensitive information or sensitive systems, leading to data breaches).

Malware distribution(Attackers can use fake digital certificates to distribute malicious software or infect systems with malware)

Steps to Reproduce: https://www.ssllabs.com/ssltest/analyze?d=www.itsecgames.com



Qualys SSL Labs

Home Projects Qualys Free Trial Contact

You are here: Home > Projects > SSL Server Test > www.itsecgames.com

SSL Report: www.itsecgames.com (31.3.96.40)

Please wait...
Testing renegotiation

Certificate #1: RSA 2048 bits (SHA256withRSA)

Server Key and Certificate #1

Subject	web.mmebvba.com Fingerprint SHA256: 9e7276cb84903692044a0e1f9b64d1426869813b55b28167913b7e49e778f87e Pin SHA256: moIIG7Pck7rm7Q7pJpb+auqA9cuCc0eOAxVTFBhY0M=
Common names	web.mmebvba.com
Alternative names	- INVALID
Serial Number	00ba5e79e0c2f743cb
Valid from	Mon, 25 May 2015 09:07:54 UTC
Valid until	Thu, 22 May 2025 09:07:54 UTC (expired 9 months and 14 days ago) EXPIRED
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	web.mmebvba.com Self-signed
Signature algorithm	SHA256withRSA
Extended Validation	No
Revocation information	None
DNS CAA	No (more info)
Trusted	No NOT TRUSTED (Why?) Mozilla Apple Android Java Windows

Additional Certificates (if supplied)

Certificates provided	1 (712 bytes)

5) Vulnerability Name: OS Identification

CWE-200:

Exposure of Sensitive Information to an Unauthorised Actor OWASP Category: A02:2021-Cryptographic Failures Description: Using a combination of remote probes (e.g., TCP/IP, SMB, HTTP, NTP, SNMP, etc.), it is possible to guess the name of the remote operating system in use. It is also possible sometimes to guess the version of the operating system.

Business Impact: If sensitive information is improperly handled or inadequately protected, it can lead to financial losses, regulatory penalties, and damage to reputation. Customers may lose trust in the organization's ability to safeguard their data, potentially resulting in a loss of business and market share. Legal consequences and compliance issues may arise, leading to additional costs. Moreover, intellectual property theft or exposure can compromise a company's competitive edge. Remediation efforts, including implementing stronger security measures and compensating affected parties, can also entail substantial expenses.

Overall, CWE-200 highlights the critical importance of robust data protection measures to safeguard an organization's financial health, reputation, and long-term viability.

Steps to Reproduce: use nmap -O TARGET to enable

Recommendation:

Implementing robust encryption protocols for data both in transit and at rest, coupled with stringent access controls and strong authentication measures.
Regular vulnerability assessments and penetration testing should be conducted to identify and rectify potential weak points. Educating employees through comprehensive security awareness training is vital, emphasising proper data handling practices and recognition of potential threats.

Employing data masking techniques for non-production environments and utilising advanced Data Loss Prevention (DLP) solutions can further fortify defences. Additionally, maintaining compliance with relevant data protection laws and regulations, as well as establishing a well-defined incident response plan, are crucial components of a comprehensive strategy to safeguard against sensitive information exposure.

This is stage 1 in the context of web application testing and security we take help from OWASP top 10 to understand them. The OWASP Top 10 is a widely recognized list of the most critical web application security risks. Understanding these risks is essential for ensuring the security of web applications

Stage 2

Overview :-

Nessus is a vulnerability scanner developed by Tenable, Inc. It is a remote scanner, meaning that it does not need to be installed on the target host to scan it. Nessus works by sending a variety of probes to the target host in order to identify vulnerabilities.

These probes can include network traffic, operating system commands, and application requests. Nessus uses a plugin-based architecture. Plugins are small pieces of code that are designed to identify specific vulnerabilities.

There are over 1200 plugins available for Nessus, covering a wide range of vulnerabilities in operating systems, applications, and network devices. When Nessus scans a host, it first uses a discovery plugin to identify the operating system and services running on the host. Once the host has been discovered, Nessus runs a series of plugins to test for vulnerabilities. For each vulnerability that Nessus finds, it provides a detailed report that includes the severity of the vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability

Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications. It can also be used to scan specific ports and services. Nessus can be configured to run scans on a schedule or manually.

Here is a step-by-step explanation of how Nessus works:

1. Nessus connects to the target host using a variety of protocols, including TCP, UDP, and ICMP.

2. Nessus sends a series of probes to the target host in order to identify its operating system and services.

3. Nessus runs a series of plugins to test for vulnerabilities.

4. Nessus generates a report that includes the severity of each vulnerability, the steps to reproduce the vulnerability, and the steps to remediate the vulnerability. Nessus is a valuable tool for security professionals who need to identify and remediate vulnerabilities in their networks. It is easy to use and provides comprehensive reports that can be used to prioritise remediation efforts. Here are some of the benefits of using Nessus:

● Comprehensive vulnerability coverage: Nessus has over 1200 plugins available, covering a wide range of vulnerabilities in operating systems, applications, and network devices.

● Easy to use: Nessus has a user-friendly interface that makes it easy to configure and run scans.

● Comprehensive reporting: Nessus provides detailed reports that include the severity of each vulnerability,the steps to reproduce the vulnerability, and the steps to remediate the vulnerability.

● Scalability: Nessus can be used to scan a variety of targets, including single hosts, networks, and web applications
.
● Flexibility: Nessus can be configured to run scans on a schedule or manually. Nessus is a powerful tool that can be used to improve the security of any network. It is a valuable asset for any security professional.

Target website :- http://testfire.net/

Target ip address:- 65.61.137.117

List of vulnerability :

s.no	Vulnerability name	Severity	plugins
1.	TLS Version 1.0 Protocol Detection	MEDIUM	1104743 2
2 .	TLS Version 1.1 Protocol Deprecated	MEDIUM	1572883
3.	SSL/TLS Diffie-Hellman Modulus <= 1024 Bits (Logjam)	LOW	83875 4
4.	ICMP Timestamp Request Remote Date Disclosure	INFO	10114 5
5.	Additional DNS Hostnames	INFO	46180

REPORT:-

1)Vulnerability Name:- 104743 - TLS Version 1.0 Protocol Detection

Severity: - MEDIUM Plugin: - 104743 Port: - 443 Description: - The remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws.

Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible. As of March 31, 2020, Endpoints that aren't enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors. PCI DSS v3.2 requires that TLS 1.0 be disabled entirely by June 30, 2018, except for POS POI terminals (and the SSL/TLS termination points to which they connect) that can be verified as not being susceptible to any known exploits. Solution: - Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Business Impact:

Continued use of TLS 1.0's encryption, known for its inherent cryptographic flaws, exposes the organization to heightened security risks, increasing the likelihood of data breaches and cyberattacks. This vulnerability jeopardizes compliance with industry standards, specifically PCI DSS v3.2, which mandates the complete cessation of TLS 1.0 use. Noncompliance risks regulatory penalties and erodes customer trust. Moreover, endpoints that lack support for TLS 1.2 and higher will experience impaired functionality with major web browsers and vendors, potentially leading to lost business opportunities and damage to the organization's reputation. Addressing this vulnerability is imperative to mitigate these multifaceted risks and maintain a secure and trustworthy online presence.

2)Vulnerability Name: - 157288 - TLS Version 1.1 Protocol

Deprecated Severity: - MEDIUM Plugin: - 157288

Port: - 443

Description: - The remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Ciphers that support encryption before MAC computation, and authenticated encryption modes such as GCM cannot be used with TLS 1.1 As of March 31, 2020, Endpoints that are not enabled for TLS 1.2 and higher will no longer function properly with major web browsers and major vendors. Solution: - Enable support for TLS 1.2 and/or 1.3, and disable support for TLS 1.1.

Business Impact: -

The continued use of TLS 1.1 with its lack of support for modern cipher suites and advanced encryption methods jeopardizes the organization's security posture, increasing vulnerability to cyber threats and potential data breaches. Additionally, endpoints not upgraded to support TLS 1.2 and higher will encounter compatibility issues with major web browsers and vendors, impacting user experience and potentially leading to missed business opportunities. Swift remediation of this vulnerability is essential to mitigate security risks and ensure seamless interactions with web browsers and vendors, preserving the organization's reputation and operational efficiency.

3)Vulnerability Name: - 83875 - SSL/TLS Diffie-Hellman **Modulus <= 1024 Bits (Logjam)**
Severity: - LOW
Plugin: - 83875 Port: - 443

Description: - The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections. Solution: - Reconfigure the service to use a unique Diffie-Hellman moduli of 2048 bits or greater.

Business Impact: - Allowing SSL/TLS connections with weak Diffie-Hellman moduli raises security concerns. An attacker with sufficient resources and computing power could compromise the shared secret relatively quickly, potentially leading to the decryption of sensitive data or the violation of connection integrity. While the severity is low, the risk of data breaches and integrity compromise should not be underestimated, and it is essential to address this vulnerability to maintain data security and user trust

4)Vulnerability Name: - 10114 - ICMP Timestamp Request Remote Date Disclosure
Severity: - INFO
Plugin: - 10114
Port: - 0

Description: - The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols. Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time. Solution: - Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Business Impact : -This does not pose an immediate threat to business operations or data security. This vulnerability allows external parties to request the system's date and time information remotely. While it does not present a significant risk, it could potentially be used by attackers for reconnaissance purposes. Therefore, it is advisable to address this vulnerability as

part of a broader security posture to reduce the risk of unauthorized data gathering and protect against potential future threats.

Stage 3

Report

Implementing Zero Trust Network Access (ZTNA) with Zscaler: Securing User-to-Application Connectivity .

• Zero Trust Network Access (ZTNA) Zero Trust Network Access (ZTNA) is an IT security framework that provides secure remote access to an organization's internal applications and data based on clearly defined access control policies.

Unlike traditional Virtual Private Networks (VPNs), which grant users broad access to the entire network, ZTNA operates on a "never trust, always verify" principle. It grants users access only to the specific applications they need, and only after their identity and device have been verified. ZTNA is a critical component of modern security architecture.

It helps organizations move away from the concept of a trusted internal network and an untrusted external network (the "castleand-moat" model). By hiding the internal network from the internet and establishing one-to-one, encrypted connections between users and applications, ZTNA drastically reduces the attack surface and stops common threats like lateral movement by attackers.

• The ZTNA Access Cycle The ZTNA cycle is a continuous process of verifying identity, establishing secure connections, and enforcing policy for every access request. It typically consists of the following steps: 1. User Request: A user, from any location (office, home, coffee shop), requests access to a specific internal application (e.g., an HR portal, a finance server, or an

internal

• The Zscaler ZTNA Cycle The Zscaler ZTNA cycle is the practical application of the ZTNA principles using the Zscaler cloud. The cycle typically consists of the following steps:

1. User Login and Authentication: A user attempts to access an internal application. They are redirected to their organization's Identity Provider (IdP) for authentication and MFA.

2. Device Posture Check (Integration): Zscaler checks with integrated endpoint protection tools to ensure the device is compliant with security policies.

3. Policy Lookup and Decision: The Zscaler cloud evaluates the request against the defined access policies. It verifies that the user, device, and context (time, location) are authorized for that specific application.

4. Establishing the Micro-tunnel: Once authorized, the Zscaler cloud instructs the user's Zscaler Client Connector and the appropriate Zscaler App Connector in the data center to establish an encrypted connection. The user is now connected to the application.

5. Traffic Inspection (Optional): For sanctioned applications, Zscaler can optionally inspect the traffic for data loss prevention (DLP) or to detect malware. 6. Logging and Analytics: All activity is logged in the Zscaler cloud portal for reporting, threat hunting, and compliance.

Future Scope: -

Future of web application testing The future of WAT is bright, as web applications become increasingly complex and sophisticated. Organizations are increasingly reliant on web applications to conduct business, and they need to be confident that their web applications are secure and reliable. Here are some of the key trends that are expected to shape the future of WAT:

Increased focus on security: Security is a top priority for all organizations, and WAT is essential for identifying and mitigating security vulnerabilities. In the future, we can expect to see even more emphasis on security testing, as web applications become increasingly targeted by cyberattacks.

● Rise of artificial intelligence (AI) and machine learning (ML): AI and ML are already being used in WAT, and their role is expected to grow in the future. AI and ML can be used to automate

repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

● Shift to cloud-based testing: More and more organizations are moving their web applications to the cloud. This trend is driving the growth of cloud-based WAT platforms. Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness.

● Increased focus on user experience (UX) testing: UX testing is essential for ensuring that web applications are easy to use and meet the needs of users. In the future, we can expect to see more focus on UX testing, as organizations increasingly recognize the importance of providing a positive user experience.

Future scope of the testing process The future scope of the testing process is bright, as software becomes increasingly complex and sophisticated.

Organisations are increasingly reliant on software to conduct business, and they need to be confident that their software is high-quality and reliable. Here are some of the key trends that are expected to shape the future of the testing process:

● Increased focus on continuous testing: Continuous testing is a methodology that involves testing software throughout the SDLC, from development to deployment. This helps to identify defects early and prevent them from causing problems later in the development process.

● Rise of AI and ML: AI and ML are already being used in the testing process, and their role is expected to grow in the future. AI and ML can be used to automate repetitive tasks, such as test case generation and execution. They can also be used to identify complex patterns and anomalies that may be difficult to detect with traditional testing methods.

● Shift to cloud-based testing: Cloud-based testing platforms offer a number of advantages, such as scalability, flexibility, and cost-effectiveness. This is driving the growth of cloud-based testing platforms.

● Increased focus on testing automation: Testing automation is the use of software to execute test cases without human intervention. Testing automation can help to save time and resources, and it can also help to improve the quality and efficiency of testing

Future scope of SOC / SEIM:- The future scope of Zero Trust Network Access (ZTNA) and the broader Zero Trust framework is poised for significant evolution, driven by emerging technologies and changing threat landscapes:

1. AI-Driven Zero Trust (AI-ZTA): Future Zero Trust implementations will leverage advanced AI and deep learning to move beyond static policies. Systems will continuously learn user behavior, predict anomalous activities before they occur, and dynamically adjust access privileges in real-time based on contextual risk, creating a truly "adaptive" security posture.

2. Integration with Edge Computing and IoT: As organizations deploy more IoT devices and edge computing nodes, Zero Trust principles will extend to these resource-constrained environments. Expect the development of lightweight Zero Trust agents and protocols that can authenticate and secure machine-to-machine (M2M) communication at the edge, preventing large-scale botnet attacks.

3. Identity-Centric Everything: The future will see identity become the ultimate security perimeter. Zero Trust will evolve to incorporate advanced identity verification methods, including continuous behavioral biometrics (keystroke dynamics, gait analysis) and decentralized identity solutions using blockchain, ensuring that the user behind the session is verified at all times.

4. Convergence with SASE Architecture: Zero Trust will be a core component of the Secure Access Service Edge (SASE) framework. This convergence will provide organizations with a unified, cloud-delivered stack that combines ZTNA, Secure Web Gateways (SWG), Cloud Access Security Brokers (CASB), and Firewall-as-a-Service (FWaaS), simplifying management and ensuring consistent security for all users, regardless of location.

Topics explored: -

Data Collection and Aggregation, Standardization and Normalisation, Enrichment and Analysis, Sharing and Distribution, Integration with Security Tools, Customization and Flexibility, Automation and Orchestration, Community Involvement, Incident Response Support, Threat Intelligence Feeds, Soc and Siem

Tools explored: - Nmap, Metasploit, Nessus, Kali Linux, OWASP ZAP, Burp Suite

-------THE END —--------